CHAYIL SECUREX | ISO 27001:2022 ISMS — Healthcare GRC Model

Information Security Management System | Risk & Control Dashboard | Ghana Data Protection Act Aligned

Cybersecurity Governance & Compliance for Regulated Healthcare Institutions | www.chayilsecurex.com

RISK SUMMARY	
Total Risks	15
Critical Risks	2
High Risks	9
Open Risks	12

CONTROL HEALTH	
Total Controls	14
Avg Effectiveness %	71.4%
Controls Implemented	7
Controls Partial/No	11

TREATMENT STATUS	
Total Treatments	9
In Progress	2
Planned	7
Completed	0

RISK APPETITE MATRIX | Scores: 1–5 Low | 6–12 Medium | 13–20 High | 21–25 Critical	
CRITICAL (21–25)	Avoid / Escalate immediately to Board & Executive leadership
HIGH (13–20)	Mitigate — Immediate remediation action required within 30 days
MEDIUM (6–12)	Treat — Manage with compensating controls; review quarterly
LOW (1–5)	Accept — Document acceptance; monitor at scheduled intervals

INFORMATION SECURITY RISK REGISTER — ISO 27001:2022 Clause 6.1.2

Identify, analyse, and evaluate all information security risks. Review quarterly or upon significant change.

Risk ID	Risk Category	Risk Name	Risk Description	Threat Source	Vulnerability	Affected Asset	Inherent Likelihood (1–5)	Inherent Impact (1–5)	Inherent Risk Score	Risk Rating	Existing Controls	Residual Likelihood (1–5)	Residual Impact (1–5)	Residual Risk Score	Risk Owner	Risk Status	Treatment Ref	Review Date	ISO Domain
R-001	Patient Data	Patient Data Breach	Unauthorised access to electronic patient health records	External attacker / Malicious insider	Weak access controls; insufficient authentication	Electronic Health Record System	5	5	25	Critical	Role-based access control (C-001)	2	3	6	IT Manager	Open	T-001	2026-06-30	A.8 — Technological
R-002	Availability	Clinical System Downtime	Clinic management / EMR system becomes unavailable, disrupting patient care	Technical failure / Power outage	No redundant systems; single points of failure	EMR System / Network Infrastructure	4	4	16	High	System backup (C-002); Power backup (C-007)	2	2	4	Operations Manager	Open	T-005	2026-06-30	A.8 — Technological
R-003	Malware	Ransomware Attack	Malware encrypts clinical systems, rendering patient records inaccessible	Phishing email / Unpatched systems	Insufficient endpoint protection; staff susceptibility to phishing	All Clinical Systems	5	5	25	Critical	Anti-malware (C-003); Backup (C-002)	3	3	9	IT Manager	Open	T-002	2026-06-30	A.8 — Technological
R-004	Insider Threat	Privileged Access Misuse	Clinical or administrative staff misuse or exfiltrate patient data	Malicious or negligent insider	Excessive access privileges; insufficient monitoring	Patient Database / EHR System	4	5	20	High	Access control (C-001); Awareness training (C-004)	2	3	6	HR Manager	In Progress	T-003	2026-06-30	A.6 — People
R-005	Data Integrity	Patient Record Corruption / Loss	Loss or corruption of patient records due to backup failure or system error	Technical failure / Human error	Untested backup procedures; inadequate data validation	Patient Database / Backup Storage	4	4	16	High	System backup (C-002)	2	2	4	IT Manager	In Progress	T-005	2026-09-30	A.8 — Technological
R-006	Compliance	Regulatory Non-Compliance	Failure to meet Ghana Data Protection Act 2012 requirements, resulting in fines or sanctions	Regulatory change / Audit failure	Lack of formal compliance programme; no documented policies	All Information Assets	3	5	15	High	Vendor risk assessment (C-005); Policy framework	2	3	6	Compliance Officer	Open	T-006	2026-06-30	A.5 — Organisational
R-007	Medical IoT	Connected Medical Device Compromise	Networked medical devices (imaging, monitors) exploited to access clinical network	External attacker	Unpatched medical device firmware; shared network segments	Medical Imaging System / Network	3	4	12	Medium	Network segmentation; Anti-malware (C-003)	2	2	4	Clinical Director	Open	T-007	2026-09-30	A.8 — Technological
R-008	Third-Party	Vendor / Third-Party Data Breach	Supplier or third-party system with access to patient data is compromised	Vendor security failure	Insufficient third-party due diligence; no vendor access controls	Patient Database / EHR via vendor API	4	5	20	High	Vendor risk assessment (C-005)	2	3	6	Procurement Manager	Open	T-004	2026-06-30	A.5 — Organisational
R-009	Physical	Unauthorised Physical Access	Unauthorised persons gain physical access to server rooms or workstations holding patient data	Tailgating / Theft	Inadequate physical access controls; no CCTV in sensitive areas	Network Infrastructure / Servers	3	4	12	Medium	Physical access control (C-006)	1	2	2	Facilities Manager	Open		2026-09-30	A.7 — Physical
R-010	Availability	Extended Power Outage	Prolonged power loss disrupts clinical operations and data availability	Infrastructure failure / Weather event	No tested generator; no UPS for all critical systems	Network Infrastructure / EHR System	3	4	12	Medium	Power backup (C-007)	2	2	4	Operations Manager	Closed		2026-09-30	A.7 — Physical
R-011	Human Error	Clinical Data Entry Error	Staff enter incorrect patient information leading to care errors or record integrity issues	Human error / Training gap	Insufficient staff training; no input validation	Patient Database / EHR System	4	4	16	High	Awareness training (C-004)	3	3	9	Clinical Director	Open	T-008	2026-09-30	A.6 — People
R-012	Data Privacy	Unauthorised Data Sharing	Patient data shared with unauthorised third parties without consent, violating Ghana DPA	Staff negligence / Deliberate disclosure	No data sharing policy; insufficient consent management	Patient Database	3	5	15	High	Access control (C-001); Data classification policy	2	3	6	Data Protection Officer	Open	T-006	2026-09-30	A.5 — Organisational
R-013	Network	Network Intrusion	Attacker gains access to the clinical network through vulnerabilities or misconfiguration	External attacker / Nation-state	Unpatched network devices; no network monitoring	Network Infrastructure	4	5	20	High	Firewall; Anti-malware (C-003)	3	3	9	IT Manager	Open	T-002	2026-06-30	A.8 — Technological
R-014	Business Continuity	No Incident Response Plan	Institution has no documented or tested incident response procedure for cyber events	N/A — Control gap	Absence of documented IR policy and procedures	All Systems	4	5	20	High	None currently in place	4	4	16	Compliance Officer	Open	T-009	2026-06-30	A.5 — Organisational
R-015	Supply Chain	Cloud Storage Data Residency Risk	Patient data stored in cloud without contractual assurance of Ghana-based or approved data residency	Cloud provider policy change	No data residency clause in vendor contracts	Patient Database / Backup Storage	3	4	12	Medium	Vendor risk assessment (C-005)	2	3	6	Procurement Manager	Open	T-004	2026-09-30	A.5 — Organisational

STATEMENT OF APPLICABILITY (SoA) — ISO 27001:2022 Clause 6.1.3(d)

Formal documentation of which ISO 27001:2022 Annex A controls are applicable. Required for certification. Must be approved by management.

Control ID	ISO 27001:2022 Control Name	Annex A Reference	Applicable? (Yes/No)	Inclusion / Exclusion Justification	Implemented? (Yes/Partial/No)	Implementation Evidence	Notes & Actions
C-001	Access Control	A.8.2	Yes	Patient data access must be restricted to authorised clinical and administrative staff only. Ghana DPA requirement.	Yes	RBAC configuration; quarterly access review records	MFA enforcement in progress — T-001
C-002	System Backup & Recovery	A.8.13	Yes	Patient data continuity is critical for clinical operations and regulatory compliance. Data must be recoverable within 4-hour RTO.	Yes	Backup logs; monthly restore test reports	Off-site backup contract to be formalised
C-003	Anti-Malware / EDR	A.8.7	Yes	Healthcare systems are high-value ransomware targets. Endpoint protection mandatory for all clinical systems.	Yes	EDR deployment report; update logs	EDR upgrade to full EDR platform — T-002
C-004	Security Awareness Training	A.6.3	Yes	Human error is the leading cause of healthcare data breaches. All staff must understand data protection obligations.	Partial	Training attendance records 2025	New starter training gap — T-008
C-005	Vendor / Supplier Risk	A.5.19	Yes	Third-party vendors with patient data access represent material risk. Ghana DPA requires data processing agreements.	No	N/A — Assessment scheduled	Vendor DPA review — T-004
C-006	Physical Access Control	A.7.4	Yes	Server rooms and workstations holding patient data require controlled physical access.	Yes	Badge access logs; CCTV records	CCTV gaps in secondary comms rooms
C-007	Power Backup	A.7.11	Yes	Clinical operations depend on continuous power. Extended outage would compromise patient care and data availability.	Yes	UPS test records; generator test logs	Not all workstations on UPS — risk accepted
C-008	Network Segmentation	A.8.22	Yes	Separating clinical, administrative, and IoT device networks reduces attack surface and lateral movement risk.	Partial	Network topology diagram	IoT VLAN separation pending — T-007
C-009	Patch Management	A.8.8	Yes	Unpatched vulnerabilities are a primary ransomware attack vector in healthcare environments.	Yes	Patch management logs	Legacy system exemption documentation needed
C-010	Data Classification	A.5.12	Yes	Patient health information (PHI) must be classified as Confidential. Ghana DPA requires appropriate handling of sensitive personal data.	Partial	Data classification policy document	Inconsistent application in departments
C-011	Incident Response	A.5.26	Yes	Ghana DPA requires breach notification to Data Protection Commission. Incident response capability is mandatory.	No	N/A — Plan not yet created	**CRITICAL gap — T-009 due 2026-03-31**
C-012	Audit Logging	A.8.15	Yes	Access to patient data must be logged and reviewable for compliance, investigation, and regulatory audit purposes.	Partial	System audit log samples	Manual review insufficient — automated alerting needed
C-013	Data Encryption	A.8.24	Yes	Patient data must be encrypted at rest and in transit. Ghana DPA sensitive data requirement.	Yes	Encryption configuration records; TLS audit	Verify all legacy transmission paths
C-014	Change Management	A.8.32	Yes	Uncontrolled changes to clinical systems risk data integrity and availability.	Partial	Change log records	Process not consistently followed
C-015	Business Continuity	A.5.29	Yes	Continuity of patient care requires documented and tested business continuity plans.	No	N/A — BCP not documented	Linked to T-005 — critical for clinical operations
C-016	Supplier Relationships	A.5.20	Yes	Contractual security obligations must be established with all suppliers accessing patient data.	Partial	Sample vendor contracts	Full contract review required — T-004
C-017	Information Transfer	A.5.14	Yes	Patient data transfer between institutions, insurers, and labs must be governed by secure transfer policies.	Partial	Email encryption policy	Formal data transfer agreement template needed
C-018	Cryptographic Controls	A.8.24	Yes	Encryption key management must be documented and keys protected from unauthorised access.	Partial	Key management procedure	Formal key management policy needed